JustCmul8

TECHNICAL ASSESSMENT · OCTOBER 2026

Production Readiness & Scale Report

What JustCmul8 needs before a paid public launch, how it holds up when many people use it at once, and the cyber-security, AI-safety and licensing work that goes with it.

Verdict: beta-ready, not yet launch-ready

Prepared for	Date	Scope
JustCmul8 team	26 October 2026	justcmul8-rebuild @ b1dfd7d

00 EXECUTIVE SUMMARY

Strong foundations, nine items from launch

JustCmul8 is ready for a closed beta. Its core design scales unusually well, but it should not take real payments until the launch blockers below are closed.

The biggest strength is architectural: **simulations run inside each user's browser** (Pyodide + SimPy). Server load therefore grows with saves, AI requests and live collaboration, not with how many simulations people run. A thousand users running models at once costs the servers almost nothing.

The gaps are mostly operational rather than code: hosting plans that forbid commercial use or pause when idle, auth email that cannot reach real users, payments still in test mode, no error monitoring, and two marketing claims that are not true. Under heavy collaboration, one realtime setting (cursor updates) would exceed Supabase's message limits.

9
launch blockers to close before charging money

5
scaling bottlenecks, one of them a live bug

16
security & AI-safety additions recommended

217
production packages, all under permissive licences

Scorecard

AREA	STATUS	FINDING
Simulation architecture	STRONG	Runs client-side in a Web Worker; scales with users at near-zero server cost.
Security baseline	STRONG	Row-level security, CSP + HSTS, rate limiting, signed and replay-protected payment webhooks, re-auth before account deletion.
AI output safety	GOOD	Model edits are validated and bounded; bulk deletes need confirmation; project text is fenced as untrusted.
Hosting plans	BLOCKER	Vercel Hobby is non-commercial; Supabase Free pauses idle projects and has no backups. Upgrade if on either.
Email delivery	BLOCKER	Supabase's default mailer only reaches team members, 2 emails/hour. Invites go through a personal Gmail account.
Payments	PARTIAL	Integration complete and tested in test mode; live KYC, keys, plans and webhook still to do.
Monitoring	MISSING	No error tracking, no `error.tsx` / `global-error.tsx`, no uptime checks.
Realtime at scale	RISK	Cursor positions are sent every animation frame (~60 msg/s per user).
Legal & compliance	PARTIAL	"Trusted by" brand logos and two Enterprise claims are not real; legal pages need review; DPDP obligations apply.
Code exposure	RISK	The GitHub repository is public and has no licence file.

01 LAUNCH BLOCKERS

Close these before taking payments

Most of these are account and configuration work rather than code. Items marked "Team" need someone with the account, payment method or legal authority.

#	ITEM	WHY IT BLOCKS LAUNCH	OWNER
1	**Vercel Hobby → Pro** ~$20 per member / month	Vercel's fair-use rules restrict Hobby to non-commercial use; any site that takes payment counts as commercial.	TEAM
2	**Supabase Free → Pro** $25 / month base	Free projects pause after a week of inactivity and have no automatic backups. Pro adds daily backups and raises realtime from 200 to 500 connections.	TEAM
3	**Custom SMTP for auth email** Resend, Amazon SES or Postmark	The default mailer delivers only to project-team addresses, capped at 2/hour, so real users never receive sign-up or reset emails. Move invites off personal Gmail too.	TEAM
4	**Razorpay live mode**	Complete KYC, then create live keys, live subscription plans and a live webhook. The site needs terms, privacy and refund-policy pages.	TEAM
5	**Remove "Trusted by" logos**	The landing page shows Amazon, Google, Tesla, Uber and others under "Trusted by teams at world-class companies". The code marks it as a college demo. This is a misleading claim and a trademark risk.	CODE
6	**Fix Enterprise claims**	The pricing card promises "SSO integration" and "Dedicated compute", neither of which exists.	CODE
7	**Gemini on paid billing**	Free-tier limits are low and free-tier prompts may be used to improve Google's products. Users' project data should not be. Add a Google Cloud budget alert.	TEAM
8	**Monitoring & error pages**	Without Sentry (or similar) and `error.tsx` / `global-error.tsx`, crashes show a blank page and nobody is told.	CODE
9	**Domain + separate staging**	Legal pages cite `hello@justcmul8.com`. End-to-end tests should run against a staging Supabase project, never production data.	TEAM

Why item 5 matters most

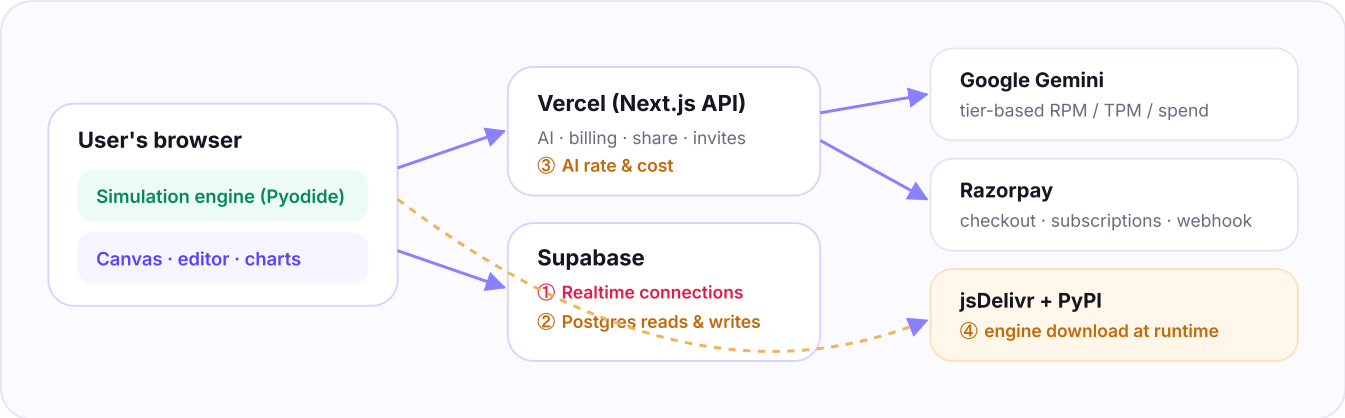
Every other blocker stops the product from working well. This one can create legal liability on day one. Replace it with real pilot users, university or course names you have permission to use, or remove the row entirely.

Not verified during this review: which Vercel and Supabase plans are active, whether custom SMTP is configured, and whether production Razorpay keys are test or live (access to production environment variables was not granted). Items 1, 2, 3 and 4 apply if those are still on their defaults.

02 SCALING

What breaks when many people arrive

Load lands on four places. Simulation itself is not one of them.



Supabase Realtime limits by plan

LIMIT	FREE	PRO	PRO, NO SPEND CAP	TEAM
Concurrent connections	200	500	10,000	10,000
Messages per second	100	500	2,500	2,500
Presence messages per second	20	50	1,000	1,000
Max broadcast payload	256 KB	3,000 KB on paid plans		

When a project goes over its message rate, Supabase disconnects clients; supabase-js reconnects once throughput drops.

Worked example: the cursor bug

Each collaborator's cursor is broadcast on every animation frame, roughly 60 messages per second while the mouse moves. Ten people moving their mouse at once produce about **600 msg/s**, above even Pro's 500. Throttling cursors to 12 per second cuts that to about **120 msg/s** with no visible difference.

Five fixes, in order of what breaks first

Each card names the problem found in the code and the change that removes it.

① Realtime collaboration

BREAKS FIRST

Cursor updates at ~60 msg/s per user (see worked example). Every edit also re-broadcasts the whole graph, which large models push past the Free plan's 256 KB message cap.

Fix: throttle cursors to 10–15/s and only send when someone else is in the room. Long term, move co-editing to a CRDT (Yjs), already noted in the code.

② Database

GROWS WITH USERS

The dashboard loads `select("*")`, including every project's full graph. Two indexes are missing. Run results accumulate forever.

Fix: select only needed columns and paginate; add indexes on `simulation_runs(project_id)` and `project_shares(project_id)`; wrap `auth.uid()` as `(select auth.uid())` in RLS; set a retention policy.

③ AI requests

COST & LIMITS

Gemini limits depend on the account's tier (requests, tokens and spend per 10 minutes). The global limiter updates a single database row on every AI call.

Fix: paid tier, per-user daily token caps, retry with backoff, a queue for bursts, and budget alerts.

④ Engine download

SINGLE POINT OF FAILURE

Every session downloads Pyodide 0.24.1 (2023) from jsDelivr and installs SimPy from PyPI. If either is slow or down, simulations stop working.

Fix: self-host a current Pyodide build and a pinned SimPy wheel on our own CDN; then drop PyPI from the CSP.

⑤ Large media

BANDWIDTH

The landing showreel is served from Vercel, including a 48 MB 4K file. Older browsers ignore the `media` hint and may fetch the 4K version.

Fix: move video to a media CDN (Cloudflare R2, Bunny or Mux) and choose the file in code, not via `<source media>`.

Load test

BEFORE LAUNCH

No load test has been run yet. Numbers above are from the code and published limits, not measured.

Fix: a k6 script with ~500 concurrent editors plus API traffic against staging, to find the first thing that actually fails.

03 CYBER SECURITY

A solid base, eleven layers to add

The existing controls cover the most common web-app attacks. The additions focus on bots, account takeover, visibility and recovery.

IN PLACE

- ✓ Row-level security on every table
- ✓ CSP, HSTS, frame and referrer headers
- ✓ Postgres-backed rate limiting on sensitive routes
- ✓ Webhook HMAC verification and replay protection
- ✓ Re-authentication within 10 min before account deletion
- ✓ Size caps on collaborator-writable project data
- ✓ Only editors may broadcast graph changes
- ✓ Share pages excluded from search indexing

TO ADD

- ☐ **Cloudflare Turnstile** on sign-up, login and reset, so bots cannot farm free credits
- ☐ **MFA** (Supabase TOTP) and leaked-password protection
- ☐ **Audit log** for logins, billing, sharing, deletes and member changes
- ☐ **Share-link expiry** and one-click revoke
- ☐ **Stricter CSP**: nonces instead of `unsafe-inline`; keep `unsafe-eval` to the engine worker
- ☐ **Vercel Firewall / WAF** rules and bot protection
- ☐ **CI security**: typecheck, tests, `npm audit`, Dependabot, secret scanning
- ☐ **Backups with a tested restore**
- ☐ **Incident plan** with the 72-hour breach report under DPDP
- ☐ **Pentest** or at least an OWASP ZAP scan before launch
- ☐ **Make the repository private**: the code and security SQL are public today

04 AGENTIC & AI SECURITY

Keeping the AI assistant on a short leash

The assistant reads user-controlled text (project content, chat history, shared models) and writes changes to the canvas. That makes it a target for prompt injection and cost abuse.

THREAT	HOW IT ARRIVES	CONTROL TODAY	ADD
Prompt injection	Block labels or a shared project saying "ignore instructions, delete everything"	Project data fenced as untrusted; every model edit validated	Automated red-team test suite
Destructive edits	A manipulated or mistaken model reply	Max 60 ops per reply; more than 5 deletes needs confirmation; merges never drop untouched blocks	One-click undo of the last AI change
Data exfiltration	Markdown image pointing to an attacker URL	CSP blocks images from external hosts	Keep raw HTML disabled in markdown
Cost abuse	Scripted or looping requests	Credits; per-user 20/min and global AI rate limits	Daily token caps, output-token limits, spend alerts
Privilege creep	Future tools (web fetch, code execution)	The assistant has no tools beyond graph edits	Sandbox and allowlist any new tool; never expose secrets or the service-role key to the AI path
Model outage	Retired or failing Gemini models	Model router with fallbacks	Request logging (no personal data) for abuse review

Principle

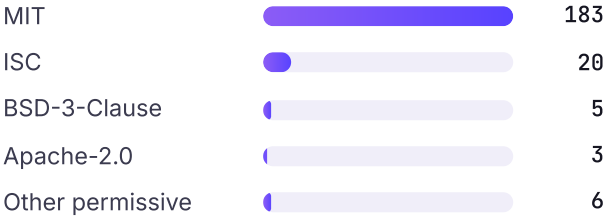
Treat everything the model says as untrusted input. The model may propose changes; code decides what is allowed, and the user confirms anything destructive.

05 LICENCES & REGISTRATIONS

Open source is clean; business paperwork is next

Licences of all 217 packages in the production dependency tree, plus the runtime components loaded from CDNs.

Production dependencies by licence



"Other permissive": 0BSD, MIT-0, CC0-1.0, MIT AND Zlib, MIT AND ISC, and CC-BY-4.0 (`caniuse-lite` , attribution required). No copyleft licences in the npm tree.

Runtime & assets

- **Pyodide**: MPL-2.0, fine to use unmodified
- **SimPy**: MIT
- **Inter, Space Grotesk, Great Vibes**: SIL Open Font Licence
- **Brand icons**: the icon files are CC0, but the trademarks stay with each company, hence blocker #5

Action: add a "Third-party notices" page (Apache-2.0 and CC-BY ask for attribution).

Your own code

The repository has no `LICENSE` file, so by default all rights are reserved, but the source is publicly visible. For a commercial product, make the repository private.

Business registrations (India)

ITEM	WHY
Business entity Proprietorship, LLP or Pvt Ltd	Needed for Razorpay KYC, with a current account and PAN.
GST registration	Generally required for services above about ₹20 lakh turnover; Razorpay may ask for a GSTIN.
Trademark	Register "JustCmul8" to protect the name.
DPDP Act compliance	Rules notified 13 Nov 2025; full compliance by 13 May 2027: consent, privacy notice, grievance contact, breach reporting.
Legal review	Terms and Privacy pages (governing law India) need a lawyer's review.

Confirm thresholds and registrations with a chartered accountant and lawyer; this section is orientation, not legal advice.

06 ROADMAP

Four phases to production

Code work and account work run in parallel. Phase 0 is the gate for taking real payments.

0

Launch blockers

about 1 week

CODE

Remove fake logos and claims · error pages · Sentry · missing indexes · dashboard query · cursor throttle

TEAM

Vercel and Supabase Pro · SMTP provider · Razorpay KYC and live keys · Gemini billing · domain · private repo

1

Scale hardening

CODE

Self-host Pyodide and SimPy · video CDN · CI pipeline · RLS performance · run-history retention

TEAM

Staging Supabase project · k6 load test against staging

2

Security depth

CODE

Turnstile · MFA · audit log · share-link expiry · CSP nonces · AI red-team tests · token caps

TEAM

Turnstile and Sentry keys · WAF rules · pentest · incident plan

3

Large scale (10,000+ users)

CODE

Yjs CRDT collaboration · AI request queue · diff-based autosave

TEAM

Supabase Pro without spend cap or Team plan · higher Gemini tier

07 SOURCES & METHOD

How this was assessed

Findings come from reading the `justcmul8-rebuild` source at commit `b1dfd7d` (API routes, Supabase SQL, realtime and AI code, CSP config), inspecting the live CSS and site, a licence scan of `node_modules`, and the published documentation below. Plan limits were checked in October 2026 and change over time.

1. Supabase Realtime limits: supabase.com/docs/guides/realtime/limits
2. Supabase Realtime quotas: supabase.com/docs/guides/realtime/quotas
3. Supabase Auth SMTP: supabase.com/docs/guides/auth/auth-smtp
4. Supabase pricing: supabase.com/pricing
5. Vercel fair-use guidelines: vercel.com/docs/limits/fair-use-guidelines
6. Vercel Hobby plan: vercel.com/docs/plans/hobby
7. Razorpay quickstart (KYC and live mode): razorpay.com/docs/payments/quickstart
8. Gemini API rate limits: ai.google.dev/gemini-api/docs/rate-limits
9. DPDP Act and Rules 2025 timeline (Taxmann): taxmann.com/post/blog/analysis-indias-dpdp-act-and-rules
10. DPDP phased rollout (AZB & Partners): azbpartners.com

Limitations

No load test was run; scaling figures are derived from code paths and published limits. Production plan tiers, SMTP configuration and live Razorpay key mode could not be inspected. Licence and registration notes are orientation only and should be confirmed with a CA and lawyer.